

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 1 頁，共 19 頁

單選題 15 題，複選題 5 題，題組題 5 題（佔 100%）

D	1. 為避免所建置之網購系統遭受憑證填充攻擊，下列何項舉措最無效果？ (A) 使用一次性密碼（One Time Password） (B) 使用多因子驗證方式（Multi-factor authentication） (C) 使用雙因子驗證方式（Two-factor authentication） (D) 強化密碼複雜度（Password Complexity）
D	2. 下列何項「不」是 ISO/ IEC 27001:2022 資訊安全目標應滿足之事項？ (A) 與資訊安全政策一致 (B) 於適切時，更新之 (C) 被傳達 (D) 以紙本文件提供
D	3. 2023 年發現某國際知名汽車大廠於將近 10 年期間，將超過 200 萬輛車子位置資訊公開在網路上，車上攝影機拍攝的影像也曝險了將近 7 年。經其內部分析，事件主要原因在於對員工的資料處理政策說明不夠徹底，導致雲端環境錯誤設定所致。請問下列何項措施，最「不」能防止類似事件再次發生？ (A) 強化員工教育訓練 (B) 定訂更明確之雲端資安政策 (C) 執行雲端弱點掃描 (D) 備份雲端環境設定
A B D	4. 控制措施實施階段可分成事前、中及後等三項。請問下列哪些屬於事中控制類型（如偵測[Detective]）的應用方式？（複選） (A) 監控入侵檢測系統（IDS） (B) 檢核稽核日誌報表（Audit Log Report Reviews） (C) 定期弱點掃描（Vulnerability Scan） (D) 監控錄影監視系統（CCTV）

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 2 頁，共 19 頁

B	5. 【題組 1】情境如附圖所示，甲金融機構（屬資通安全管理法規範對象）於本開發案起案前對於受託者之選任作業，下列何者最「不」適切？ A 公司主要核心業務係提供國內各大金融機構（均屬資通安全管理法規範對象）有關系統之客製化開發業務，合作夥伴 B 公司為長年承接 A 公司所下包有關金融機構委託業務。甲為國內首屈一指之金融機構，今有一金融系統委外開發專案需求，此專案為一大型系統開發案，包含委外開發 W 核心系統、X 系統（資通系統防護需求等級為高級）、Y 系統（資通系統防護需求等級為中級）以及 Z 系統（資通系統防護需求等級為普級）各乙式，委託金額為新台幣捌佰捌拾捌萬元整，專案開發為期一年。 (A) 確認受託者配置充足且經適當之資格訓練之人員執行受託業務 (B) 確認受託者擁有 ISO 9001 專業證照 (C) 確認受託者具有類似業務經驗之資通安全專業人員 (D) 確認受託者具備完善之資通安全管理措施
C	6. 【題組 1】情境如附圖所示，A 公司今成功承攬甲金融機構（屬資通安全管理法規範對象）所委託之系統開發案，因案量過大，故 A 公司一如以往，擬尋求合作夥伴 B 公司執行本案之部分系統開發業務，並尋求取得甲金融機構之同意。有關甲金融機構就 A 公司辦理受託業務之複委託事項，其應注意之事項，下列說明何者最「不」適切？ A 公司主要核心業務係提供國內各大金融機構（均屬資通安全管理法規範對象）有關系統之客製化開發業務，合作夥伴 B 公司為長年承接 A 公司所下包有關金融機構委託業務。甲為國內首屈一指之金融機構，今有一金融系統委外開發專案需求，此專案為一大型系統開發案，包含委外開發 W 核心系統、X 系統（資通系統防護需求等級為高級）、Y 系統（資通系統防護需求等級為中級）以及 Z 系統（資通系統防護需求等級為普級）各乙式，委託金額為新台幣捌佰捌拾捌萬元整，專案開發為期一年。 (A) 複委託之範圍 (B) 複委託之對象

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 3 頁，共 19 頁

	(C) 複委託之金額 (D) 複委託之受託者應具備之資通安全維護措施
C	7. 【題組 1】情境如附圖所示，A 公司承攬甲金融機構（屬資通安全管理法規範對象）所委託之系統開發案，B 公司受 A 公司之複委託，辦理部份系統開發業務，且 B 公司所負責之 Y 系統，部份系統程式碼係取自外部第三方所開發之程式碼。下列說明何者最適切？ A 公司主要核心業務係提供國內各大金融機構（均屬資通安全管理法規範對象）有關系統之客製化開發業務，合作夥伴 B 公司為長年承接 A 公司所下包有關金融機構委託業務。甲為國內首屈一指之金融機構，今有一金融系統委外開發專案需求，此專案為一大型系統開發案，包含委外開發 W 核心系統、X 系統（資通系統防護需求等級為高級）、Y 系統（資通系統防護需求等級為中級）以及 Z 系統（資通系統防護需求等級為普級）各乙式，委託金額為新台幣捌佰捌拾捌萬元整，專案開發為期一年。 (A) 受託業務之委託金額未達新台幣一千萬元以上，故無需辦理安全性檢測 (B) 本案應由 B 公司負責提供安全性檢測證明 (C) 甲金融機構自行或另行委託第三方進行安全性檢測 (D) 應標示 B 公司非自行開發之內容，但無須提供其來源及提供授權證明
B C D	8. 【題組 1】情境如附圖所示，A 公司承攬甲金融機構（屬資通安全管理法規範對象）所委託之系統開發案，B 公司受 A 公司之複委託，辦理部份系統開發業務，B 公司於開發所負責之 Y 系統過程中，系統開發工程師將開發區之電腦私自連接外部網路，因故導致該電腦受駭客攻擊，造成部份系統程式碼外洩之重大資通安全事件。關於此資通安全事件之處置下列哪些最適切？（複選）

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 4 頁，共 19 頁

	A 公司主要核心業務係提供國內各大金融機構（均屬資通安全管理法規對象）有關系統之客製化開發業務，合作夥伴 B 公司為長年承接 A 公司所下包有關金融機構委託業務。甲為國內首屈一指之金融機構，今有一金融系統委外開發專案需求，此專案為一大型系統開發案，包含委外開發 W 核心系統、X 系統（資通系統防護需求等級為高級）、Y 系統（資通系統防護需求等級為中級）以及 Z 系統（資通系統防護需求等級為普級）各乙式，委託金額為新台幣捌佰捌拾捌萬元整，專案開發為期一年。 (A) 辦理對 B 公司網路維護工程師之適任性查核 (B) B 公司通報 A 公司並通知甲金融機構資通安全事件 (C) B 公司採行補救措施 (D) 甲金融機構決議解除複委託業務，確認複委託之受託者返還、移交、刪除或銷毀履行契約而持有之資料
D	9. 下列關於「縱深防禦」的描述，何者較「不」合適？ (A) 縱深防禦是一種網路安全策略，它使用多種安全產品和做法來保護組織的網路、Web 資產和資源 (B) 縱深防禦有時與「分層式安全性」一詞互換使用，因為它依賴於多個控制層（實體、技術和管理）的安全解決方案 (C) 縱深防禦透過實作多種安全產品和做法可以幫助偵測和阻止出現的攻擊，使組織能夠有效地緩解各種威脅 (D) 縱深防禦安全策略中，運用一個功能強大的產品來阻止攻擊者和其他威脅
A	10. 設計職務區隔（SoD）控制措施時，宜考量共謀之可能性。小型組織可能發現難以實施職務區隔，但於可能及可行之情況下，宜儘可能使用此原則。難以區隔職務時，宜考量採行相關控制措施來輔助，下列何者控制措施較「不」適切？ (A) 全權負責 (B) 活動監視 (C) 稽核存底 (D) 管理監督

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 5 頁，共 19 頁

B	11. 請問下列對於資訊安全管理實務的描述何者較「不」正確？ (A) 縱深防禦（Defense in Depth）指在整實體、系統、網路或網宇（Cyberspace）中建置了多層的防禦機制 (B) 零信任架構（ZTA）已成為國內主流，目前國內企業組織的資訊及工控系統都已廣為採用零信任架構 (C) 僅知原則（Need-to-Know Principle）與最小權限原則（Principle of Least Privilege，POLP）仍然是可供參考的資安管理實務原則 (D) 職務區隔（Separation of Duties，SoD）也是管理層面的安全機制，也可以透過技術層面來加強使得工作分成多人分層負責避免個人進行非授權的工作或提升偵測的能力
A C	12. 依照 CNS 27002: 2023 的建議，於使用電子通訊設施進行資訊傳送時，規則、程序及協議宜考量下列那些項目？（複選） (A) 偵測及防範可透過使用電子通訊傳輸之惡意軟體 (B) 方便使用者存取，電子郵件自動轉寄至外部郵件位址 (C) 保護以附件形式通訊之敏感性電子資訊 (D) 依使用者習慣自主使用即時傳訊等外部公共服務
D	13. 【題組 2】情境如附圖所示，依據我國上市上櫃公司資通安全控管指引，為協助公司強化資通安全防護及管理機制，於該指引中明文規定必須設置專責人員訂定資通安全政策及目標，本項明文要求必須由公司內部那一個職務以上核定政策及目標？

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 6 頁，共 19 頁

	在準備上市公司的董事會會議中，資通安全是議程的重點。此次會議主要討論如何加強公司的資通安全防護及管理機制，應對生成式 AI 的威脅，以及了解最新的資安框架更新如何融入公司治理之中。 資通安全主管向董事會介紹了我國上市上櫃公司資通安全控管指引，強調該指引要求設置專責人員來訂定資通安全政策及目標。其中一位董事成員提出了生成式 AI 在攻擊中的利用。指出生成式 AI 已成為攻擊者的利器之一，資通安全主管解釋了這一技術的戰術進程，並強調公司需要強化對此類威脅的防護措施。 在外部議題討論時外部輔導顧問提到美國國家標準技術研究院（NIST）創建的網路安全框架（Cyber Security Framework，CSF）在 2024 年 3 月公佈了最新的 2.0 版，資通安全主管提到其 CSF 改版的差別，將功能從原有的 5 個主功能擴增為 6 大主要功能。新的管理功能不僅加強了原有的 5 個功能，還使 CSF 在資源配置上更具效率。最終管理部門，針對上市櫃公司引導中的人員教育訓練應落實至公司的每一位成員，並且應有其檢核的制度，確保教育訓練的有效性，身為資安全主管的你，應該如何面對這些議題。 (A) 監查人 (B) 資訊主管 (C) 董事 (D) 副總經理
D	14. 【題組 2】情境如附圖所示，生成式 AI 也成為攻擊者利用的利器之一，為使生成式 AI 於攻擊進程中識別，MITRE ATT&CK 也在 2024 年 4 月 26 日所釋出的 15.01 版本中將 AI 納入，並於技術中新增了一個分類名為 T1588.007 Artificial Intelligence。而攻擊與防護是相庭抗禮，上述新增的攻擊技術，為下列 ATT&CK 的那一個戰術進程？

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 7 頁，共 19 頁

在準備上市公司的董事會會議中，資通安全是議程的重點。此次會議主要討論如何加強公司的資通安全防護及管理機制，應對生成式 AI 的威脅，以及了解最新的資安框架更新如何融入公司治理之中。

資通安全主管向董事會介紹了我國上市上櫃公司資通安全控管指引，強調該指引要求設置專責人員來訂定資通安全政策及目標。其中一位董事成員提出了生成式 AI 在攻擊中的利用。指出生成式 AI 已成為攻擊者的利器之一，資通安全主管解釋了這一技術的戰術進程，並強調公司需要強化對此類威脅的防護措施。

在外部議題討論時外部輔導顧問提到美國國家標準技術研究院（NIST）創建的網路安全框架（Cyber Security Framework，CSF）在 2024 年 3 月公佈了最新的 2.0 版，資通安全主管提到其 CSF 改版的差別，將功能從原有的 5 個主功能擴增為 6 大主要功能。新的管理功能不僅加強了原有的 5 個功能，還使 CSF 在資源配置上更具效率。最終管理部門，針對上市櫃公司引導中的人員教育訓練應落實至公司的每一位成員，並且應有其檢核的制度，確保教育訓練的有效性，身為資安全主管的你，應該如何面對這些議題。

- (A) Impact 衝擊
- (B) Persistence 維持
- (C) Defense Evasion 防禦規避
- (D) Resource Development 資源開發

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 8 頁，共 19 頁

- C 15. 【題組 2】情境如附圖所示，NIST CSF 於近年來已經成為世界各國使用率最高的資安框架，2024 年 3 月 NIST 公佈了最新版的 2.0 版，其功能自原有的 5 個主功能，擴增成為 6 大主要功能，原有的維度為一個維護的防護流程，新的管理功能加強了原有的 5 個功能外，也使 CSF 更有效率的方式將寶貴且有限的資源做最佳的投注。在 2.0 版新增的功能，於發佈的資料中稱之為下列何項？

在準備上市公司的董事會會議中，資通安全是議程的重點。此次會議主要討論如何加強公司的資通安全防護及管理機制，應對生成式 AI 的威脅，以及了解最新的資安框架更新如何融入公司治理之中。

資通安全主管向董事會介紹了我國上市上櫃公司資通安全控管指引，強調該指引要求設置專責人員來訂定資通安全政策及目標。其中一位董事成員提出了生成式 AI 在攻擊中的利用。指出生成式 AI 已成為攻擊者的利器之一，資通安全主管解釋了這一技術的戰術進程，並強調公司需要強化對此類威脅的防護措施。

在外部議題討論時外部輔導顧問提到美國國家標準技術研究院（NIST）創建的網路安全框架（Cyber Security Framework, CSF）在 2024 年 3 月公佈了最新的 2.0 版，資通安全主管提到其 CSF 改版的差別，將功能從原有的 5 個主功能擴增為 6 大主要功能。新的管理功能不僅加強了原有的 5 個功能，還使 CSF 在資源配置上更具效率。最終管理部門，針對上市櫃公司引導中的人員教育訓練應落實至公司的每一位成員，並且應有其檢核的制度，確保教育訓練的有效性，身為資安全主管的你，應該如何面對這些議題。

- (A) 識別（Identify）
- (B) 響應（Respond）
- (C) 治理（Govern）
- (D) 復原（Recover）

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 9 頁，共 19 頁

B D	16. 【題組 2】情境如附圖所示，下列那些選項描述的狀況，何者符合資安三要素中完整性的特性？（複選） 在準備上市公司的董事會會議中，資通安全是議程的重點。此次會議主要討論如何加強公司的資通安全防護及管理機制，應對生成式 AI 的威脅，以及了解最新的資安框架更新如何融入公司治理之中。 資通安全主管向董事會介紹了我國上市上櫃公司資通安全控管指引，強調該指引要求設置專責人員來訂定資通安全政策及目標。其中一位董事成員提出了生成式 AI 在攻擊中的利用。指出生成式 AI 已成為攻擊者的利器之一，資通安全主管解釋了這一技術的戰術進程，並強調公司需要強化對此類威脅的防護措施。 在外部議題討論時外部輔導顧問提到美國國家標準技術研究院（NIST）創建的網路安全框架（Cyber Security Framework，CSF）在 2024 年 3 月公佈了最新的 2.0 版，資通安全主管提到其 CSF 改版的差別，將功能從原有的 5 個主功能擴增為 6 大主要功能。新的管理功能不僅加強了原有的 5 個功能，還使 CSF 在資源配置上更具效率。最終管理部門，針對上市櫃公司引導中的人員教育訓練應落實至公司的每一位成員，並且應有其檢核的制度，確保教育訓練的有效性，身為資安全主管的你，應該如何面對這些議題。 (A) 人員到職後，因預設密碼未進行變更，該員的帳號被登入並且外洩了公司的資料 (B) 公司執行資安檢測時，發現 SQL Injection 的問題，變更部分資料庫內容 (C) 公司的電子郵件中透過應透過憑證進行電子郵件加密 (D) 因使用者資安意識不足，點擊了勒索軟體，以致部分文件內容無法讀取
C	17. 關於 NIST SP 800-207 零信任架構（Zero Trust Architecture）中的網路敘述，下列何項錯誤？ (A) 企業內部網路不可視為隱式信任區（Implicit Trust Zone） (B) 內部網路中的設備可能非企業所有或受企業管控 (C) 遠距企業人員可完全信任他們本地的網路連線 (D) 資產與流程於企業和非企業之基礎設施移動時，必須為一致的安全標準

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 10 頁，共 19 頁

C	18. 關於設計供應鏈遠端存取架構的敘述，下列何項最「不」適切？ (A) 身份識別應該要有多重身份驗證機制（MFA） (B) 可以透過虛擬私人網路（Virtual Private Network，VPN）做存取控制 (C) 使用資料外洩防護（Data Loss Prevention，DLP）即可做到個人資料保護 (D) 可以透過傳輸加密保護營業秘密
A	19. 由於企業對於大型語言模型（LLM）的使用需求大增，企業內的程式開發與研發團隊使用前述技術的雲端服務也日益頻繁，諸如 ChatGPT 及 Copilot 等等，然而為了避免公司機密資料外洩，高階管理階層要求加強對於程式開發與研發團隊使用雲端大型語言模型服務加強控制，請問下列做法何者較「不」適切？ (A) 強化微分段架構安全 (B) 強化 WEB 應用層防火牆的安全政策，尤其是程式片段的上傳 (C) 清查 LLM 的使用情形，限制非核可 LLM 服務的使用 (D) 加強雲端 API 連結使用的確認與管理
B C D	20. 在安全開發生命週期（Secure System Develop Life Cycle，SSDLC）中，有關開發與測試階段，可以協助降低資安風險的有下列哪些項目？（複選） (A) 部署網頁應用程式防火牆 (B) 滲透測試 (C) 原始碼檢測 (D) 第三方元件資安檢測

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 11 頁，共 19 頁

C	21. 【題組 3】情境如附圖所示。請問公司在建置此網路販售系統時，下列何項為最「不」需要考慮的項目？ K 公司為國內股票上市食品之製造商，公司新建置網路販售系統，將產品直接銷售給國內的消費者，並暫時不提供將所販售產品寄到本國以外的地區。 (A) 主管機關的要求 (B) 法令規定 (C) 公司資安長的專長 (D) 系統安全需求
B	22. 【題組 3】情境如附圖所示。公司於建置系統時評估自行負責金流作業風險過大，決定將網路金流作業交由合格之金資服務機構辦理，不自行處理金流作業。請問此項決策屬下列何項風險處理措施？ K 公司為國內股票上市食品之製造商，公司新建置網路販售系統，將產品直接銷售給國內的消費者，並暫時不提供將所販售產品寄到本國以外的地區。 (A) 風險緩解 (Risk mitigation) (B) 風險避免 (Risk avoidance) (C) 風險分擔 (Risk sharing) (D) 風險保留 (Risk retention)
C	23. 【題組 3】情境如附圖所示。建置網路販售系統時，公司考量該系統之機密性、可用性、完整性規劃了相關控制項目，請問下列何項系統建置規劃「不」屬機密性之考量？ K 公司為國內股票上市食品之製造商，公司新建置網路販售系統，將產品直接銷售給國內的消費者，並暫時不提供將所販售產品寄到本國以外的地區。 (A) 規定使用多因子認證登入系統 (B) 要求定期更改密碼 (C) 建置即時系統備援機制 (D) 使用 TLS 1.3 (Transport Layer Security) 加密通訊協定

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 12 頁，共 19 頁

B C	24. 【題組 3】情境如附圖所示。網路販售系統上線 6 個月後，公司收到證券主管機關通知大量會員資料被人於國外網站上架販售。請問發生此個資外洩事件，公司於回應此資安事件時，須注意下列哪些法令規章？（複選） K 公司為國內股票上市食品之製造商，公司新建置網路販售系統，將產品直接銷售給國內的消費者，並暫時不提供將所販售產品寄到本國以外的地區。 (A) 電腦處理個人資料保護法 (B) 上市上櫃公司資通安全管控指引 (C) 個人資料保護法 (D) 食品安全衛生管理法
B	25. 您服務的公司不同國家或地域皆有設置服務據點，而您也是該公司總部單位的資訊安全長，當您預計制定該公司的資訊安全發展策略時，下列何者是資訊安全長最「不」需優先評估的因素？ (A) 基層員工和管理階層對於資通安全不同的認知態度 (B) 能否解決因為不同國家時差，而連絡到更上層的高層主管 (C) 不同地域所需遵循的法規和行政規範之項目 (D) 全球各國的營業安控政策及流程的一致性
C	26. Arc 公司於數日前遭受電子郵件社交工程攻擊，員工點選外部寄來的電子郵件並開啟電子郵件夾帶的勒索軟體，造成公司內容多台電腦內的檔案被加密。經過事件風險評鑑後，發覺針對此類事件未來改善的方式為：事前缺乏教育訓練，以及事發時未有備份資料足以提供使用者復原使用。請問，上述所指二種控制措施，分別屬於何種控制措施類型？ (A) Detective & Corrective (B) Corrective & Detective (C) Preventive & Corrective (D) Detective & Preventive

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 13 頁，共 19 頁

C	27. 關於風險分析與評估之敘述，下列何者最「不」適切？ (A) 公司最好至少每年定期執行一次風險評鑑 (B) 公司營運重大改變時，應進行風險評鑑 (C) 重大風險項目完成風險處理後，不需進行風險再評估 (D) 進行風險分析與評估前，應先了解相關背景資訊（例如：法規要求、技術環境…）
B D	28. 甲公司因 A 製程所用之所有機台當機，造成生產線停工、影響產品生產，經公司資安人員分析評估後，確認發生原因為廠商透過 USB 更新機台應用程式過程控制不當，導致機台程式異常所致。請問下列哪些選項為降低機台程式更新異常的風險緩解（Risk Mitigation）措施？（複選） (A) 將 A 製程委外處理 (B) 要求 USB 使用前，應掃毒確認無異常 (C) 要求負責機台之廠商提供保證金，減少公司因此產生可能的營運損失 (D) 要求機台需分多批次更新程式，每批更新確認安全無誤後，方可進行下一批之更新作業

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

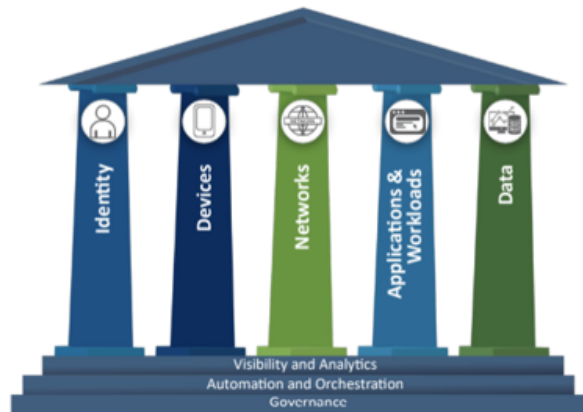
科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 14 頁，共 19 頁

- B 29. 【題組 4】情境如附圖所示。關於規劃零信任資安架構的敘述，下列何者有誤？

2020 年美國國家標準技術研究院（NIST）正式頒布標準文件 SP800-207：零信任架構（Zero Trust Architecture, ZTA），零信任已從概念探討階段進入實務部署規劃。



陳生為跨國企業之資安管理人員，因應供應鏈上下游要求，包含遠端使用供應鏈管理系統、資料存取、設備辨識等項目規劃零信任架構。因此他參考了國際 NIST 標準文件 SP800-207 後，開始進行規劃，以下是他遇到的問題，請協助他完成這個安全架構規劃任務。

- (A) 白名單之非法遠端連線（RDP）是零信任在網路層的控制項目之一
- (B) 只要設定白名單就可以完全符合零信任之需求
- (C) 資安微隔離（Micro-Segmentation）是零信任在網路層的控制項目之一
- (D) 資料存取的零信任可以透過防治資料外洩（DLP）方案落實

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

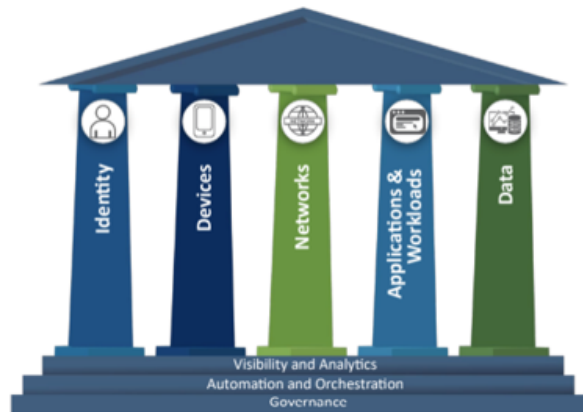
科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 15 頁，共 19 頁

- A 30. 【題組 4】情境如附圖所示。針對遠端使用供應鏈管理系統、資料存取、設備辨識等項目規劃零信任架構。在設計資安架構時，「不」包含下列何項原則？

2020 年美國國家標準技術研究院（NIST）正式頒布標準文件 SP800-207：零信任架構（Zero Trust Architecture, ZTA），零信任已從概念探討階段進入實務部署規劃。



陳生為跨國企業之資安管理人員，因應供應鏈上下游要求，包含遠端使用供應鏈管理系統、資料存取、設備辨識等項目規劃零信任架構。因此他參考了國際 NIST 標準文件 SP800-207 後，開始進行規劃，以下是他遇到的問題，請協助他完成這個安全架構規劃任務。

- (A) 資產採購
- (B) 元件關係
- (C) 工作流程規劃
- (D) 存取政策

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

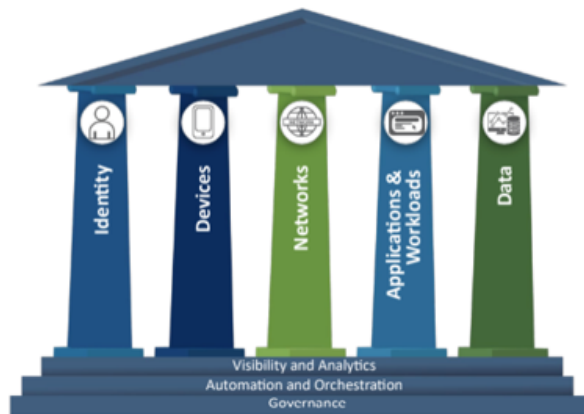
科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 16 頁，共 19 頁

- C 31. 【題組 4】情境如附圖所示。CISA（美國網路安全暨基礎設施安全局）零信任成熟模型（Zero Trust Maturity Model，ZTMM），針對遠端使用供應鏈管理系統、資料存取、設備辨識等項目規劃零信任架構。關於設計與部署原則的敘述，下列何者最正確？

2020 年美國國家標準技術研究院（NIST）正式頒布標準文件 SP800-207：零信任架構（Zero Trust Architecture，ZTA），零信任已從概念探討階段進入實務部署規劃。



陳生為跨國企業之資安管理人員，因應供應鏈上下游要求，包含遠端使用供應鏈管理系統、資料存取、設備辨識等項目規劃零信任架構。因此他參考了國際 NIST 標準文件 SP800-207 後，開始進行規劃，以下是他遇到的問題，請協助他完成這個安全架構規劃任務。

- (A) 員工自帶裝置可以不算在零信任架構中
- (B) 雲端資料來源與運算服務，不納入零信任架構
- (C) 所有的資料來源與運算服務，都要被當作是資源
- (D) 在允許存取之前，所有的資源的身分鑑別與授權機制，不需監控結果動態決定

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

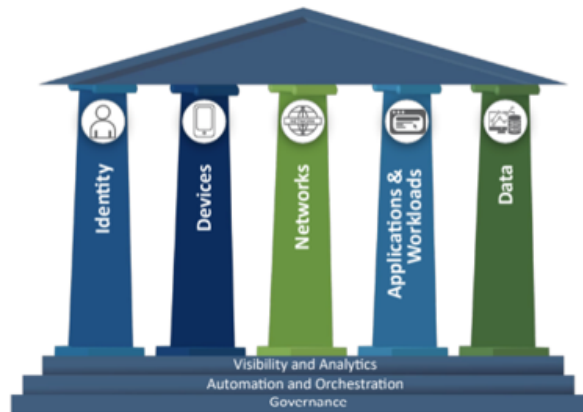
科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 17 頁，共 19 頁

- A 32. 【題組 4】情境如附圖所示。關於 NIST SP 800-207 零信任架構(Zero Trust Architecture)的基本規則敘述，下列何者正確？
B
C (複選)

2020 年美國國家標準技術研究院 (NIST) 正式頒布標準文件 SP800-207：零信任架構 (Zero Trust Architecture, ZTA)，零信任已從概念探討階段進入實務部署規劃。



陳生為跨國企業之資安管理人員，因應供應鏈上下游要求，包含遠端使用供應鏈管理系統、資料存取、設備辨識等項目規劃零信任架構。因此他參考了國際 NIST 標準文件 SP800-207 後，開始進行規劃，以下是他遇到的問題，請協助他完成這個安全架構規劃任務。

- (A) 所有的通訊都需被保護，無論其所在之網路位置
(B) 須觀察與量測所擁有資產與相關資產，其完整性與安全態勢
(C) 運算服務 (Computing Service) 和資料來源 (Data Sources) 皆可視為資源
(D) 應先蒐集資產、網路架構等現狀，建立資產清冊

- A 33. 有關風險處理選項之敘述，下列何項「有誤」？
(A) 風險處理選項一定為相互排斥的
(B) 選擇最適當的風險處理選項應包含達成目標所獲得之潛在利益及實施的成本
(C) 風險處理選項包含承受或增加風險以尋求機會
(D) 風險處理選項包含移除風險來源

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 18 頁，共 19 頁

C	34. 針對風險處理的描述，下列何者最「不」適切？ (A) 風險處理計畫的核准，須取得風險擁有者的核准 (B) 風險處理需考量組織所獲得之潛在利益與實施的成本等因素，選擇最適當的風險處理方式 (C) 執行完風險處理後，預計會降低到可接受風險以下，剩餘之資訊安全風險不需要風險擁有者再次的核可 (D) 風險處理可以選取多種方式同時進行
B	35. 有關如何進行風險處理的描述，下列何者最「不」適切？ (A) 在風險處理的過程中，有可能會需要因為導入的工具，管理新的風險 (B) 超過可接受風險之資產，應先將此風險列入觀察，後續再予以處理 (C) 風險擁有者與利害相關者，都需要瞭解風險處理後之剩餘風險的結果 (D) 風險處理後之殘餘風險，必須文件化記錄並定期審查，確認風險處理是有效控制風險的
A B C	36. 資料庫伺服器時間校正功能發生狀況的風險問題，最應加強下列哪幾項控制措施？（複選） (A) 事件分析 (B) 時間同步 (C) 網路連通監控 (D) 存取控制
D	37. 【題組 5】情境如附圖所示，在美國國家標準暨技術研究院（NIST）訂定的軟體開發安全框架（Secure Software Development Framework, SSDF）中提到第三方元件弱點的風險管控，下列達成風險管控的方式何者錯誤？ 各產業對於軟體供應鏈安全的韌性要求，包含供應鏈上下游的公司資訊安全、軟體安全等。在風險管理方面可以透過參考或導入 ISO 系統以達到有效的管控。 (A) 盤點各系統使用的第三方元件清單 (B) 清查第三方元件的弱點

114 年度第 1 次 資訊安全工程師能力鑑定 中級試題

科目：I21 資訊安全規劃實務

考試日期：114 年 3 月 22 日

第 19 頁，共 19 頁

	(C) 持續監控第三方元件弱點情資 (D) 使用較不知名的第三方元件
D	38. 【題組 5】情境如附圖所示，在風險管理上，使用威脅評估模型進行供應鏈資安風險評估。請問下列何者敘述錯誤？ 各產業對於軟體供應鏈安全的韌性要求，包含供應鏈上下游的公司資訊安全、軟體安全等。在風險管理方面可以透過參考或導入 ISO 系統以達到有效的管控。 (A) DREAD 是威脅建模的一種模式 (B) STRIDE 是威脅建模的一種模式 (C) VAST 是威脅建模的一種模式 (D) NIST 是國際標準的威脅建模
D	39. 【題組 5】情境如附圖所示，下列何者「不」是正確的軟體風險管理控制方法？ 各產業對於軟體供應鏈安全的韌性要求，包含供應鏈上下游的公司資訊安全、軟體安全等。在風險管理方面可以透過參考或導入 ISO 系統以達到有效的管控。 (A) 第三方元件弱點管理 (B) 於合約中載明軟體開發之資安修補責任 (C) 定期巡檢軟體弱點與更新 (D) 透過第三方軟體庫進行更新
A B	40. 【題組 5】情境如附圖所示，在軟體供應鏈中的風險管理上，有以下哪些方式進行資安預防及檢測？（複選） 各產業對於軟體供應鏈安全的韌性要求，包含供應鏈上下游的公司資訊安全、軟體安全等。在風險管理方面可以透過參考或導入 ISO 系統以達到有效的管控。 (A) 軟體物料清單（Software Bill of Materials，SBOM） (B) 原始碼檢測及防毒掃描 (C) IAS-99 (D) SEMI 197